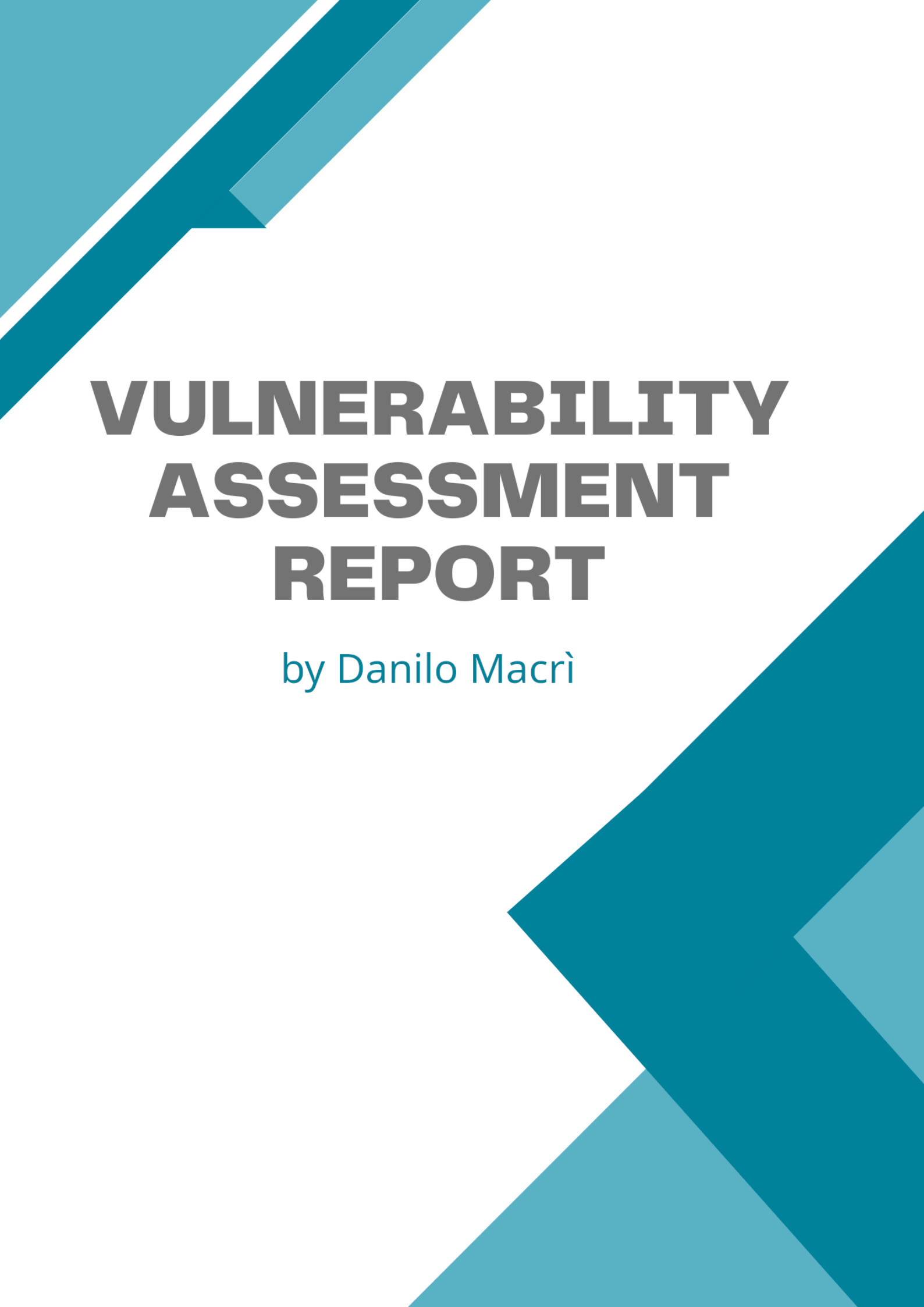


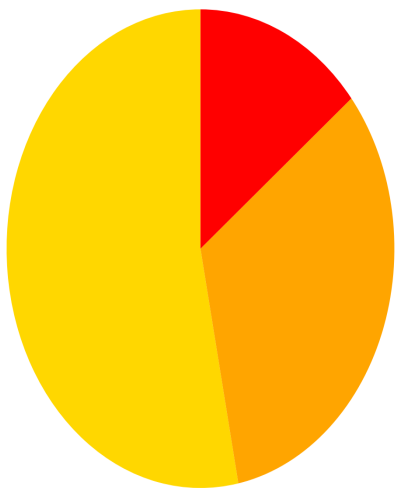


# **VULNERABILITY ASSESSMENT REPORT**

by Danilo Macrì

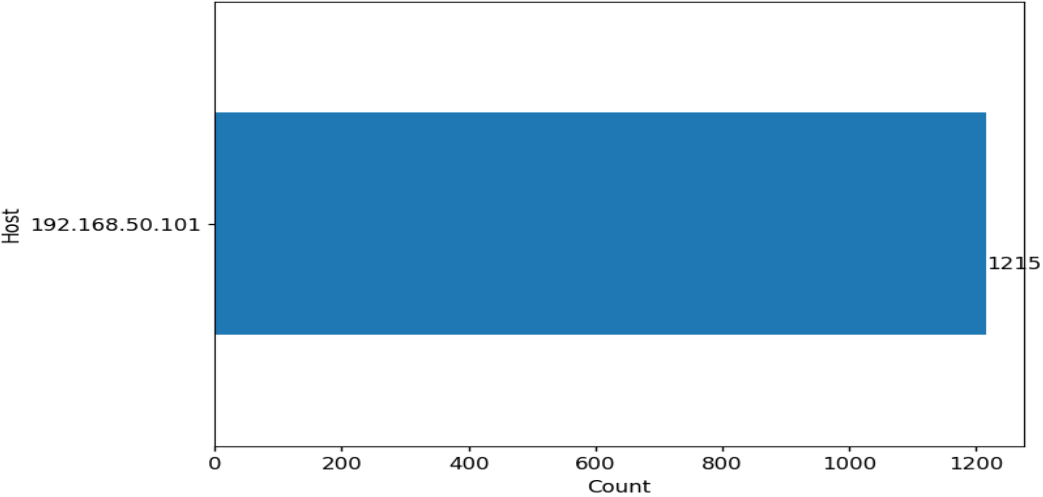
# At a Glance

Total



| Risk Severity | Count |
|---------------|-------|
| High          | 509   |
| Medium        | 313   |
| Critical      | 136   |

Top 5 Hosts with the Most Vulnerabilities



List of Most Common Vulnerabilities

| Name                                                                                                                              | Count |
|-----------------------------------------------------------------------------------------------------------------------------------|-------|
| Ubuntu 8.04 LTS / 10.04 LTS / 10.10 / 11.04 / 11.10 : mysql-5.1, mysql-dfsg-5.0, mysql-dfsg-5.1 vulnerabilities (USN-1397-1)      | 57    |
| Ubuntu 6.06 LTS / 8.04 LTS / 9.04 / 9.10 / 10.04 LTS / 10.10 : linux, linux-ec2, linux-source-2.6.15 vulnerabilities (USN-1000-1) | 28    |
| Ubuntu 8.04 LTS : linux vulnerabilities (USN-1072-1)                                                                              | 24    |
| Ubuntu 6.06 LTS / 8.04 LTS / 8.10 / 9.04 / 9.10 : linux, linux-source-2.6.15 vulnerabilities (USN-864-1)                          | 21    |
| Ubuntu 6.06 LTS / 8.04 LTS / 9.04 / 9.10 / 10.04 LTS : linux, linux-source-2.6.15 vulnerabilities (USN-947-1)                     | 21    |

Most CVEs

| CVE           | Count |
|---------------|-------|
| CVE-2008-0166 | 7     |
| CVE-2011-0441 | 4     |
| CVE-2009-3555 | 3     |
| CVE-2008-4989 | 3     |
| CVE-2008-4098 | 3     |

Most Recommended Improvements

| Solution                                                                              | Count |
|---------------------------------------------------------------------------------------|-------|
| Update the affected packages.                                                         | 610   |
| Update the affected mysql-server-5.0 and / or mysql-server-5.1 packages.              | 58    |
| Update the affected libfreetype6 package.                                             | 24    |
| Update the affected freetype2-demos, libfreetype6 and / or libfreetype6-dev packages. | 15    |
| Update the affected libssl0.9.8, libssl1.0.0 and / or openssl packages.               | 12    |

# Vulnerability Information

Critical

## Bash Remote Code Execution (Shellshock)

### Description:

The remote host is running a version of Bash that is vulnerable to command injection via environment variable manipulation. Depending on the configuration of the system, an attacker could remotely execute arbitrary code.

### Solution:

Update Bash.

### Hosts:

192.168.50.101

Critical

## **Bind Shell Backdoor Detection**

### **Description:**

A shell is listening on the remote port without any authentication being required. An attacker may use it by connecting to the remote port and sending commands directly.

### **Solution:**

Verify if the remote host has been compromised, and reinstall the system if necessary.

### **Hosts:**

192.168.50.101

Critical

## **Debian OpenSSH/OpenSSL Package Random Number Generator Weakness**

### **Description:**

The remote SSH host key has been generated on a Debian or Ubuntu system which contains a bug in the random number generator of its OpenSSL library.

The problem is due to a Debian packager removing nearly all sources of entropy in the remote version of OpenSSL.

An attacker can easily obtain the private part of the remote key and use this to set up decipher the remote session or set up a man in the middle attack.

### **Solution:**

Consider all cryptographic material generated on the remote host to be guessable. In particular, all SSH, SSL and OpenVPN key material should be re-generated.

### **Hosts:**

192.168.50.101

Critical

## **Debian OpenSSH/OpenSSL Package Random Number Generator Weakness (SSL check)**

### **Description:**

The remote x509 certificate on the remote SSL server has been generated on a Debian or Ubuntu system which contains a bug in the random number generator of its OpenSSL library.

The problem is due to a Debian packager removing nearly all sources of entropy in the remote version of OpenSSL.

An attacker can easily obtain the private part of the remote key and use this to decipher the remote session or set up a man in the middle attack.

### **Solution:**

Consider all cryptographic material generated on the remote host to be guessable. In particular, all SSH, SSL and OpenVPN key material should be re-generated.

### **Hosts:**

192.168.50.101

## Critical SSL Version 2 and 3 Protocol Detection

### Description:

The remote service accepts connections encrypted using SSL 2.0 and/or SSL 3.0. These versions of SSL are affected by several cryptographic flaws, including:

- An insecure padding scheme with CBC ciphers.
- Insecure session renegotiation and resumption schemes.

An attacker can exploit these flaws to conduct man-in-the-middle attacks or to decrypt communications between the affected service and clients.

Although SSL/TLS has a secure means for choosing the highest supported version of the protocol (so that these versions will be used only if the client or server support nothing better), many web browsers implement this in an unsafe way that allows an attacker to downgrade a connection (such as in POODLE). Therefore, it is recommended that these protocols be disabled entirely.

NIST has determined that SSL 3.0 is no longer acceptable for secure communications. As of the date of enforcement found in PCI DSS v3.1, any version of SSL will not meet the PCI SSC's definition of 'strong cryptography'.

### Solution:

Consult the application's documentation to disable SSL 2.0 and 3.0. Use TLS 1.2 (with approved cipher suites) or higher instead.

### Hosts:

192.168.50.101



Critical

**Ubuntu 6.06 LTS / 7.04 / 7.10 / 8.04 LTS : gnutls12, gnutls13 vulnerabilities (USN-613-1)**

**Description:**

Multiple flaws were discovered in the connection handling of GnuTLS. A remote attacker could exploit this to crash applications linked against GnuTLS, or possibly execute arbitrary code with permissions of the application's user.

Note that Tenable Network Security has extracted the preceding description block directly from the Ubuntu security advisory. Tenable has attempted to automatically clean and format it as much as possible without introducing additional issues.

**Solution:**

Update the affected packages.

**Hosts:**

192.168.50.101

Critical

## **Ubuntu 6.06 LTS / 7.04 / 7.10 / 8.04 LTS : libxml2 vulnerabilities (USN-644-1)**

### **Description:**

It was discovered that libxml2 did not correctly handle long entity names. If a user were tricked into processing a specially crafted XML document, a remote attacker could execute arbitrary code with user privileges or cause the application linked against libxml2 to crash, leading to a denial of service. (CVE-2008-3529)

USN-640-1 fixed vulnerabilities in libxml2. When processing extremely large XML documents with valid entities, it was possible to incorrectly trigger the newly added vulnerability protections. This update fixes the problem. (CVE-2008-3281).

Note that Tenable Network Security has extracted the preceding description block directly from the Ubuntu security advisory. Tenable has attempted to automatically clean and format it as much as possible without introducing additional issues.

### **Solution:**

Update the affected packages.

### **Hosts:**

192.168.50.101

Critical

**Ubuntu 6.06 LTS / 7.04 / 7.10 / 8.04 LTS : linux, linux-source-2.6.15/20/22  
vulnerabilities (USN-625-1)**

**Description:**

Dirk Nehring discovered that the IPsec protocol stack did not correctly handle fragmented ESP packets. A remote attacker could exploit this to crash the system, leading to a denial of service. (CVE-2007-6282)

Johannes Bauer discovered that the 64bit kernel did not correctly handle hrtimer updates. A local attacker could request a large expiration value and cause the system to hang, leading to a denial of service. (CVE-2007-6712)

Tavis Ormandy discovered that the ia32 emulation under 64bit kernels did not fully clear uninitialized data. A local attacker could read private kernel memory, leading to a loss of privacy. (CVE-2008-0598)

Jan Kratochvil discovered that PTRACE did not correctly handle certain calls when running under 64bit kernels. A local attacker could exploit this to crash the system, leading to a denial of service. (CVE-2008-1615)

Wei Wang discovered that the ASN.1 decoding routines in CIFS and SNMP NAT did not correctly handle certain length values. Remote attackers could exploit this to execute arbitrary code or crash the system. (CVE-2008-1673)

Paul Marks discovered that the SIT interfaces did not correctly manage allocated memory. A remote attacker could exploit this to fill all available memory, leading to a denial of service. (CVE-2008-2136)

David Miller and Jan Lieskovsky discovered that the Sparc kernel did not correctly range-check memory regions allocated with mmap. A local attacker could exploit this to crash the system, leading to a denial of service. (CVE-2008-2137)

The sys\_utimensat system call did not correctly check file permissions in certain situations. A local attacker could exploit this to modify the file times of arbitrary files which could lead to a denial of service. (CVE-2008-2148)

Brandon Edwards discovered that the DCCP system in the kernel did not correctly check feature lengths. A remote attacker could exploit this to execute arbitrary code. (CVE-2008-2358)

A race condition was discovered between ptrace and utrace in the kernel. A local attacker could exploit this to crash the system, leading to a denial of service. (CVE-2008-2365)

The copy\_to\_user routine in the kernel did not correctly clear memory destination addresses when running on 64bit kernels. A local attacker could exploit this to gain access to sensitive kernel memory, leading to a loss of privacy. (CVE-2008-2729)

The PPP over L2TP routines in the kernel did not correctly handle certain messages. A remote attacker could send a specially crafted packet that could crash the system or execute arbitrary code. (CVE-2008-2750)

Gabriel Campana discovered that SCTP routines did not correctly check for large addresses. A local user could exploit this to allocate all available memory, leading to a denial of service. (CVE-2008-2826).

Note that Tenable Network Security has extracted the preceding description block directly from the Ubuntu security advisory. Tenable has attempted to automatically clean and format it as much as possible without introducing additional issues.

## **Solution:**

Update the affected packages.

## **Hosts:**

192.168.50.101

Critical

## **Ubuntu 6.06 LTS / 7.10 / 8.04 LTS / 8.10 : libxml2 vulnerabilities (USN-673-1)**

### **Description:**

Drew Yao discovered that libxml2 did not correctly handle certain corrupt XML documents. If a user or automated system were tricked into processing a malicious XML document, a remote attacker could cause applications linked against libxml2 to enter an infinite loop, leading to a denial of service. (CVE-2008-4225)

Drew Yao discovered that libxml2 did not correctly handle large memory allocations. If a user or automated system were tricked into processing a very large XML document, a remote attacker could cause applications linked against libxml2 to crash, leading to a denial of service. (CVE-2008-4226).

Note that Tenable Network Security has extracted the preceding description block directly from the Ubuntu security advisory. Tenable has attempted to automatically clean and format it as much as possible without introducing additional issues.

### **Solution:**

Update the affected packages.

### **Hosts:**

192.168.50.101

Critical

**Ubuntu 6.06 LTS / 7.10 / 8.04 LTS : linux-source-2.6.15/22, linux vulnerabilities (USN-714-1)**

**Description:**

Hugo Dias discovered that the ATM subsystem did not correctly manage socket counts. A local attacker could exploit this to cause a system hang, leading to a denial of service. (CVE-2008-5079)

It was discovered that the libertas wireless driver did not correctly handle beacon and probe responses. A physically near-by attacker could generate specially crafted wireless network traffic and cause a denial of service. Ubuntu 6.06 was not affected. (CVE-2008-5134)

It was discovered that the inotify subsystem contained watch removal race conditions. A local attacker could exploit this to crash the system, leading to a denial of service. (CVE-2008-5182)

Dann Frazier discovered that in certain situations sendmsg did not correctly release allocated memory. A local attacker could exploit this to force the system to run out of free memory, leading to a denial of service. Ubuntu 6.06 was not affected. (CVE-2008-5300)

It was discovered that the ATA subsystem did not correctly set timeouts. A local attacker could exploit this to cause a system hang, leading to a denial of service. (CVE-2008-5700)

It was discovered that the ib700 watchdog timer did not correctly check buffer sizes. A local attacker could send a specially crafted ioctl to the device to cause a system crash, leading to a denial of service. (CVE-2008-5702)

It was discovered that in certain situations the network scheduler did not correctly handle very large levels of traffic. A local attacker could produce a high volume of UDP traffic resulting in a system hang, leading to a denial of service. Ubuntu 8.04 was not affected. (CVE-2008-5713).

Note that Tenable Network Security has extracted the preceding description block directly from the Ubuntu security advisory. Tenable has attempted to automatically clean and format it as much as possible without introducing additional issues.

**Solution:**

Update the affected packages.

**Hosts:**

192.168.50.101

Critical  
**Ubuntu 6.06 LTS / 8.04 LTS / 8.10 / 9.04 / 9.10 : linux, linux-source-2.6.15  
vulnerabilities (USN-894-1)**

## **Description:**

Amerigo Wang and Eric Sesterhenn discovered that the HFS and ext4 filesystems did not correctly check certain disk structures. If a user were tricked into mounting a specially crafted filesystem, a remote attacker could crash the system or gain root privileges. (CVE-2009-4020, CVE-2009-4308)

It was discovered that FUSE did not correctly check certain requests. A local attacker with access to FUSE mounts could exploit this to crash the system or possibly gain root privileges. Ubuntu 9.10 was not affected. (CVE-2009-4021)

It was discovered that KVM did not correctly decode certain guest instructions. A local attacker in a guest could exploit this to trigger high scheduling latency in the host, leading to a denial of service. Ubuntu 6.06 was not affected. (CVE-2009-4031)

It was discovered that the OHCI firmware driver did not correctly handle certain ioctls. A local attacker could exploit this to crash the system, or possibly gain root privileges. Ubuntu 6.06 was not affected. (CVE-2009-4138)

Tavis Ormandy discovered that the kernel did not correctly handle O\_ASYNC on locked files. A local attacker could exploit this to gain root privileges. Only Ubuntu 9.04 and 9.10 were affected. (CVE-2009-4141)

Neil Horman and Eugene Teo discovered that the e1000 and e1000e network drivers did not correctly check the size of Ethernet frames. An attacker on the local network could send specially crafted traffic to bypass packet filters, crash the system, or possibly gain root privileges. (CVE-2009-4536, CVE-2009-4538)

It was discovered that 'print-fatal-signals' reporting could show arbitrary kernel memory contents. A local attacker could exploit this, leading to a loss of privacy. By default this is disabled in Ubuntu and did not affect Ubuntu 6.06. (CVE-2010-0003)



Olli Jarva and Tuomo Untinen discovered that IPv6 did not correctly handle jumbo frames. A remote attacker could exploit this to crash the system, leading to a denial of service. Only Ubuntu 9.04 and 9.10 were affected. (CVE-2010-0006)

Florian Westphal discovered that bridging netfilter rules could be modified by unprivileged users. A local attacker could disrupt network traffic, leading to a denial of service. (CVE-2010-0007)

Al Viro discovered that certain mremap operations could leak kernel memory. A local attacker could exploit this to consume all available memory, leading to a denial of service. (CVE-2010-0291).

Note that Tenable Network Security has extracted the preceding description block directly from the Ubuntu security advisory. Tenable has attempted to automatically clean and format it as much as possible without introducing additional issues.

## **Solution:**

Update the affected packages.

## **Hosts:**

192.168.50.101

Critical

## **Ubuntu 6.06 LTS / 8.04 LTS / 8.10 / 9.04 : dhcp3 vulnerability (USN-803-1)**

### **Description:**

It was discovered that the DHCP client as included in dhcp3 did not verify the length of certain option fields when processing a response from an IPv4 dhcp server. If a user running Ubuntu 6.06 LTS or 8.04 LTS connected to a malicious dhcp server, a remote attacker could cause a denial of service or execute arbitrary code as the user invoking the program, typically the 'dhcp' user. For users running Ubuntu 8.10 or 9.04, a remote attacker should only be able to cause a denial of service in the DHCP client. In Ubuntu 9.04, attackers would also be isolated by the AppArmor dhclient3 profile.

Note that Tenable Network Security has extracted the preceding description block directly from the Ubuntu security advisory. Tenable has attempted to automatically clean and format it as much as possible without introducing additional issues.

### **Solution:**

Update the affected packages.

### **Hosts:**

192.168.50.101

Critical

## **Ubuntu 6.06 LTS / 8.04 LTS / 8.10 / 9.04 : libxml2 vulnerabilities (USN-815-1)**

### **Description:**

It was discovered that libxml2 did not correctly handle root XML document element DTD definitions. If a user were tricked into processing a specially crafted XML document, a remote attacker could cause the application linked against libxml2 to crash, leading to a denial of service. (CVE-2009-2414)

It was discovered that libxml2 did not correctly parse Notation and Enumeration attribute types. If a user were tricked into processing a specially crafted XML document, a remote attacker could cause the application linked against libxml2 to crash, leading to a denial of service. (CVE-2009-2416)

USN-644-1 fixed a vulnerability in libxml2. This advisory provides the corresponding update for Ubuntu 9.04.

It was discovered that libxml2 did not correctly handle long entity names. If a user were tricked into processing a specially crafted XML document, a remote attacker could execute arbitrary code with user privileges or cause the application linked against libxml2 to crash, leading to a denial of service. (CVE-2008-3529).

Note that Tenable Network Security has extracted the preceding description block directly from the Ubuntu security advisory. Tenable has attempted to automatically clean and format it as much as possible without introducing additional issues.

### **Solution:**

Update the affected packages.

### **Hosts:**

192.168.50.101

Critical

## **Ubuntu 6.06 LTS / 8.04 LTS / 8.10 : apt vulnerabilities (USN-762-1)**

### **Description:**

Alexandre Martani discovered that the APT daily cron script did not check the return code of the date command. If a machine is configured for automatic updates and is in a time zone where DST occurs at midnight, under certain circumstances automatic updates might not be applied and could become permanently disabled. (CVE-2009-1300)

Michael Casadevall discovered that APT did not properly verify repositories signed with a revoked or expired key. If a repository were signed with only an expired or revoked key and the signature was otherwise valid, APT would consider the repository valid. (<https://launchpad.net/bugs/356012>)

Note that Tenable Network Security has extracted the preceding description block directly from the Ubuntu security advisory. Tenable has attempted to automatically clean and format it as much as possible without introducing additional issues.

### **Solution:**

Update the affected packages.

### **Hosts:**

192.168.50.101

Critical

**Ubuntu 6.06 LTS / 8.04 LTS / 9.04 / 9.10 / 10.04 LTS / 10.10 : linux, linux-ec2,  
linux-source-2.6.15 vulnerabilities (USN-1000-1)**

**Description:**

Dan Rosenberg discovered that the RDS network protocol did not correctly check certain parameters. A local attacker could exploit this gain root privileges. (CVE-2010-3904)

Al Viro discovered a race condition in the TTY driver. A local attacker could exploit this to crash the system, leading to a denial of service. (CVE-2009-4895)

Dan Rosenberg discovered that the MOVE\_EXT ext4 ioctl did not correctly check file permissions. A local attacker could overwrite append-only files, leading to potential data loss. (CVE-2010-2066)

Dan Rosenberg discovered that the swapexit xfs ioctl did not correctly check file permissions. A local attacker could exploit this to read from write-only files, leading to a loss of privacy. (CVE-2010-2226)

Suresh Jayaraman discovered that CIFS did not correctly validate certain response packets. A remote attacker could send specially crafted traffic that would crash the system, leading to a denial of service. (CVE-2010-2248)

Ben Hutchings discovered that the ethtool interface did not correctly check certain sizes. A local attacker could perform malicious ioctl calls that could crash the system, leading to a denial of service. (CVE-2010-2478, CVE-2010-3084)

James Chapman discovered that L2TP did not correctly evaluate checksum capabilities. If an attacker could make malicious routing changes, they could crash the system, leading to a denial of service. (CVE-2010-2495)

Neil Brown discovered that NFSv4 did not correctly check certain write requests. A remote attacker could send specially crafted traffic that could crash the system or possibly gain root privileges. (CVE-2010-2521)

David Howells discovered that DNS resolution in CIFS could be spoofed. A local attacker could exploit this to control DNS replies, leading to a loss of privacy and possible privilege escalation. (CVE-2010-2524)

Dan Rosenberg discovered a flaw in gfs2 file system's handling of acls (access control lists). An unprivileged local attacker could exploit this flaw to gain access or execute any file stored in the gfs2 file system. (CVE-2010-2525)

Bob Peterson discovered that GFS2 rename operations did not correctly validate certain sizes. A local attacker could exploit this to crash the system, leading to a denial of service. (CVE-2010-2798)

Eric Dumazet discovered that many network functions could leak kernel stack contents. A local attacker could exploit this to read portions of kernel memory, leading to a loss of privacy. (CVE-2010-2942, CVE-2010-3477)

Sergey Vlasov discovered that JFS did not correctly handle certain extended attributes. A local attacker could bypass namespace access rules, leading to a loss of privacy. (CVE-2010-2946)

Tavis Ormandy discovered that the IRDA subsystem did not correctly shut down. A local attacker could exploit this to cause the system to crash or possibly gain root privileges. (CVE-2010-2954)

Brad Spengler discovered that the wireless extensions did not correctly validate certain request sizes. A local attacker could exploit this to read portions of kernel memory, leading to a loss of privacy. (CVE-2010-2955)

Tavis Ormandy discovered that the session keyring did not correctly check for its parent. On systems without a default session keyring, a local attacker could exploit this to crash the system, leading to a denial of service. (CVE-2010-2960)

Kees Cook discovered that the V4L1 32bit compat interface did not correctly validate certain parameters. A local attacker on a 64bit system with access to a video device could exploit this to gain root privileges. (CVE-2010-2963)

Toshiyuki Okajima discovered that ext4 did not correctly check certain parameters. A local attacker could exploit this to crash the system or overwrite the last block of large files. (CVE-2010-3015)

Tavis Ormandy discovered that the AIO subsystem did not correctly validate certain parameters. A local attacker could exploit this to crash the system or possibly gain root privileges. (CVE-2010-3067)

Dan Rosenberg discovered that certain XFS ioctls leaked kernel stack contents. A local attacker could exploit this to read portions of kernel memory, leading to a loss of privacy. (CVE-2010-3078)

Tavis Ormandy discovered that the OSS sequencer device did not correctly shut down. A local attacker could exploit this to crash the system or possibly gain root privileges. (CVE-2010-3080)

Dan Rosenberg discovered that the ROSE driver did not correctly check parameters. A local attacker with access to a ROSE network device could exploit this to crash the system or possibly gain root privileges. (CVE-2010-3310)

Thomas Dreibholz discovered that SCTP did not correctly handle appending packet chunks. A remote attacker could send specially crafted traffic to crash the system, leading to a denial of service. (CVE-2010-3432)

Dan Rosenberg discovered that the CD driver did not correctly check parameters. A local attacker could exploit this to read arbitrary kernel memory, leading to a loss of privacy. (CVE-2010-3437)

Dan Rosenberg discovered that the Sound subsystem did not correctly validate parameters. A local attacker could exploit this to crash the system, leading to a denial of service. (CVE-2010-3442)

Dan Rosenberg discovered that SCTP did not correctly handle HMAC calculations. A remote attacker could send specially crafted traffic that would crash the system, leading to a denial of service. (CVE-2010-3705)

Joel Becker discovered that OCFS2 did not correctly validate on-disk symlink structures. If an attacker were able to trick a user or automated system into mounting a specially crafted filesystem, it could crash the system or expose kernel memory, leading to a loss of privacy. (CVE-2010-NNN2).

Note that Tenable Network Security has extracted the preceding description block directly from the Ubuntu security advisory. Tenable has attempted to automatically clean and format it as much as possible without introducing additional issues.

## **Solution:**

Update the affected packages.

## **Hosts:**

192.168.50.101

Critical

**Ubuntu 6.06 LTS / 8.04 LTS / 9.04 / 9.10 / 10.04 LTS / 10.10 : openssl vulnerabilities (USN-1003-1)**

**Description:**

It was discovered that OpenSSL incorrectly handled return codes from the bn\_wexpand function calls. A remote attacker could trigger this flaw in services that used SSL to cause a denial of service or possibly execute arbitrary code with application privileges. This issue only affected Ubuntu 6.06 LTS, 8.04 LTS, 9.04 and 9.10. (CVE-2009-3245)

It was discovered that OpenSSL incorrectly handled certain private keys with an invalid prime. A remote attacker could trigger this flaw in services that used SSL to cause a denial of service or possibly execute arbitrary code with application privileges. The default compiler options for affected releases should reduce the vulnerability to a denial of service. (CVE-2010-2939).

Note that Tenable Network Security has extracted the preceding description block directly from the Ubuntu security advisory. Tenable has attempted to automatically clean and format it as much as possible without introducing additional issues.

**Solution:**

Update the affected packages.

**Hosts:**

192.168.50.101



## Critical

### Ubuntu 7.10 / 8.04 LTS / 8.10 : linux, linux-source-2.6.22 vulnerabilities (USN-751-1)

#### Description:

NFS did not correctly handle races between fcntl and interrupts. A local attacker on an NFS mount could consume unlimited kernel memory, leading to a denial of service. Ubuntu 8.10 was not affected. (CVE-2008-4307)

Sparc syscalls did not correctly check mmap regions. A local attacker could cause a system panic, leading to a denial of service. Ubuntu 8.10 was not affected. (CVE-2008-6107)

In certain situations, cloned processes were able to send signals to parent processes, crossing privilege boundaries. A local attacker could send arbitrary signals to parent processes, leading to a denial of service. (CVE-2009-0028)

The kernel keyring did not free memory correctly. A local attacker could consume unlimited kernel memory, leading to a denial of service. (CVE-2009-0031)

The SCTP stack did not correctly validate FORWARD-TSN packets. A remote attacker could send specially crafted SCTP traffic causing a system crash, leading to a denial of service. (CVE-2009-0065)

The eCryptfs filesystem did not correctly handle certain VFS return codes. A local attacker with write-access to an eCryptfs filesystem could cause a system crash, leading to a denial of service. (CVE-2009-0269)

The Dell platform device did not correctly validate user parameters. A local attacker could perform specially crafted reads to crash the system, leading to a denial of service. (CVE-2009-0322)

The page fault handler could consume stack memory. A local attacker could exploit this to crash the system or gain root privileges with a Kprobe registered. Only Ubuntu 8.10 was affected. (CVE-2009-0605)

Network interfaces statistics for the SysKonnnect FDDI driver did not

check capabilities. A local user could reset statistics, potentially interfering with packet accounting systems. (CVE-2009-0675)

The getsockopt function did not correctly clear certain parameters. A local attacker could read leaked kernel memory, leading to a loss of privacy. (CVE-2009-0676)

The ext4 filesystem did not correctly clear group descriptors when resizing. A local attacker could exploit this to crash the system, leading to a denial of service. (CVE-2009-0745)

The ext4 filesystem did not correctly validate certain fields. A local attacker could mount a malicious ext4 filesystem, causing a system crash, leading to a denial of service. (CVE-2009-0746, CVE-2009-0747, CVE-2009-0748)

The syscall interface did not correctly validate parameters when crossing the 64-bit/32-bit boundary. A local attacker could bypass certain syscall restricts via crafted syscalls. (CVE-2009-0834, CVE-2009-0835)

The shared memory subsystem did not correctly handle certain shmctl calls when CONFIG\_SHMEM was disabled. Ubuntu kernels were not vulnerable, since CONFIG\_SHMEM is enabled by default. (CVE-2009-0859)

The virtual consoles did not correctly handle certain UTF-8 sequences. A local attacker on the physical console could exploit this to cause a system crash, leading to a denial of service. (CVE-2009-1046).

Note that Tenable Network Security has extracted the preceding description block directly from the Ubuntu security advisory. Tenable has attempted to automatically clean and format it as much as possible without introducing additional issues.

## **Solution:**

Update the affected packages.

## **Hosts:**

192.168.50.101

Critical

**Ubuntu 8.04 LTS / 10.04 LTS / 10.10 / 11.04 / 11.10 : freetype vulnerabilities  
(USN-1403-1)**

**Description:**

Mateusz Jurczyk discovered that FreeType did not correctly handle certain malformed BDF font files. If a user were tricked into using a specially crafted font file, a remote attacker could cause FreeType to crash. (CVE-2012-1126)

Mateusz Jurczyk discovered that FreeType did not correctly handle certain malformed BDF font files. If a user were tricked into using a specially crafted font file, a remote attacker could cause FreeType to crash. (CVE-2012-1127)

Mateusz Jurczyk discovered that FreeType did not correctly handle certain malformed TrueType font files. If a user were tricked into using a specially crafted font file, a remote attacker could cause FreeType to crash. (CVE-2012-1128)

Mateusz Jurczyk discovered that FreeType did not correctly handle certain malformed Type42 font files. If a user were tricked into using a specially crafted font file, a remote attacker could cause FreeType to crash. (CVE-2012-1129)

Mateusz Jurczyk discovered that FreeType did not correctly handle certain malformed PCF font files. If a user were tricked into using a specially crafted font file, a remote attacker could cause FreeType to crash. (CVE-2012-1130)

Mateusz Jurczyk discovered that FreeType did not correctly handle certain malformed TrueType font files. If a user were tricked into using a specially crafted font file, a remote attacker could cause FreeType to crash. (CVE-2012-1131)

Mateusz Jurczyk discovered that FreeType did not correctly handle certain malformed Type1 font files. If a user were tricked into using a specially crafted font file, a remote attacker could cause FreeType to crash. (CVE-2012-1132)

Mateusz Jurczyk discovered that FreeType did not correctly handle

certain malformed BDF font files. If a user were tricked into using a specially crafted font file, a remote attacker could cause FreeType to crash or possibly execute arbitrary code with user privileges. (CVE-2012-1133)

Mateusz Jurczyk discovered that FreeType did not correctly handle certain malformed Type1 font files. If a user were tricked into using a specially crafted font file, a remote attacker could cause FreeType to crash or possibly execute arbitrary code with user privileges. (CVE-2012-1134)

Mateusz Jurczyk discovered that FreeType did not correctly handle certain malformed TrueType font files. If a user were tricked into using a specially crafted font file, a remote attacker could cause FreeType to crash. (CVE-2012-1135)

Mateusz Jurczyk discovered that FreeType did not correctly handle certain malformed BDF font files. If a user were tricked into using a specially crafted font file, a remote attacker could cause FreeType to crash or possibly execute arbitrary code with user privileges. (CVE-2012-1136)

Mateusz Jurczyk discovered that FreeType did not correctly handle certain malformed BDF font files. If a user were tricked into using a specially crafted font file, a remote attacker could cause FreeType to crash. (CVE-2012-1137)

Mateusz Jurczyk discovered that FreeType did not correctly handle certain malformed TrueType font files. If a user were tricked into using a specially crafted font file, a remote attacker could cause FreeType to crash. (CVE-2012-1138)

Mateusz Jurczyk discovered that FreeType did not correctly handle certain malformed BDF font files. If a user were tricked into using a specially crafted font file, a remote attacker could cause FreeType to crash. (CVE-2012-1139)

Mateusz Jurczyk discovered that FreeType did not correctly handle certain malformed PostScript font files. If a user were tricked into using a specially crafted font file, a remote attacker could cause FreeType to crash. (CVE-2012-1140)

Mateusz Jurczyk discovered that FreeType did not correctly handle certain malformed BDF font files. If a user were tricked into using a specially crafted font file, a remote attacker could cause FreeType to crash. (CVE-2012-1141)

Mateusz Jurczyk discovered that FreeType did not correctly handle certain malformed Windows FNT/FON font files. If a user were tricked into using a specially crafted font file, a remote attacker could cause FreeType to crash. (CVE-2012-1142)

Mateusz Jurczyk discovered that FreeType did not correctly handle certain malformed font files. If a user were tricked into using a specially crafted font file, a remote attacker could cause FreeType to crash. (CVE-2012-1143)

Mateusz Jurczyk discovered that FreeType did not correctly handle certain malformed TrueType font files. If a user were tricked into using a specially crafted font file, a remote attacker could cause FreeType to crash or possibly execute arbitrary code with user privileges. (CVE-2012-1144).

Note that Tenable Network Security has extracted the preceding description block directly from the Ubuntu security advisory. Tenable has attempted to automatically clean and format it as much as possible without introducing additional issues.

## **Solution:**

Update the affected libfreetype6 package.

## **Hosts:**

192.168.50.101

Critical

## **Ubuntu 8.04 LTS / 10.04 LTS / 11.04 / 11.10 : samba vulnerability (USN-1423-1)**

### **Description:**

Brian Gorenc discovered that Samba incorrectly calculated array bounds when handling remote procedure calls (RPC) over the network. A remote, unauthenticated attacker could exploit this to execute arbitrary code as the root user. (CVE-2012-1182).

Note that Tenable Network Security has extracted the preceding description block directly from the Ubuntu security advisory. Tenable has attempted to automatically clean and format it as much as possible without introducing additional issues.

### **Solution:**

Update the affected samba package.

### **Hosts:**

192.168.50.101

Critical

## **Ubuntu 8.04 LTS / 8.10 / 9.04 : apr vulnerability (USN-813-1)**

### **Description:**

Matt Lewis discovered that apr did not properly sanitize its input when allocating memory. If an application using apr processed crafted input, a remote attacker could cause a denial of service or potentially execute arbitrary code as the user invoking the application.

Note that Tenable Network Security has extracted the preceding description block directly from the Ubuntu security advisory. Tenable has attempted to automatically clean and format it as much as possible without introducing additional issues.

### **Solution:**

Update the affected libapr1, libapr1-dbg and / or libapr1-dev packages.

### **Hosts:**

192.168.50.101